Infraestructura de Servicios Blockchain de España

ECO1030 - Política de pausado/bloqueo SCs/borrado de datos

Proyecto ISBE	**Autor** José Antonio Fernández
Fecha 19.12.2025	**Colaboradores** GT Gobernanza

Financiado por la Unión Europea NextGenerationEU
Plan de Recuperación, Transformación y Resiliencia
Comunidad de Madrid
ALASTRIA

Índice

1. Objeto y alcance 2
2. Definiciones y marco de referencia 3
2.1 Definiciones clave 3
2.2 Otras definiciones 4
2.3 Marco de referencia 4
2.4 Reglas de interpretación 4
3. Principios 6
4. Roles y responsabilidades 7
4.1 Roles del ecosistema 7
4.2 Matriz RACI 7
5. Reglas obligatorias 9
5.1 Reglas de arquitectura para la interrupción 9
5.2 Reglas de privacidad y gestión del dato 9
5.3 Reglas de borrado (inutilización criptográfica) 9
5.4 Reglas de intervención (vías de pausado) 10
5.5 Mecanismo de filtrado técnico y régimen sancionador 10
6. Procedimientos clave 12
6.1 Vía 1: Pausado de emergencia (actuación de oficio) 12
6.2 Vía 2: Bloqueo disciplinario (retirada forzosa) 13
6.3 Vía 3: Pausado voluntario (mantenimiento) 13
6.4 Procedimiento de borrado de datos 14
7. Supervisión, revisión y actualización 16
7.1 Objetivo y alcance de la supervisión 16
7.2 Indicadores y umbrales (KPI mínimos) 16
7.3 Revisión y actualización de la política 16
8. Anexos 17

Financiado por la Unión Europea NextGenerationEU
Plan de Recuperación, Transformación y Resiliencia
Comunidad de Madrid

1. Objeto y alcance

Esta política establece el marco normativo, los principios rectores y los procedimientos técnicos para la interrupción controlada (pausado o bloqueo) de *Smart Contracts* en operación y para la ejecución efectiva del borrado de datos personales en el ecosistema ISBE.

Su finalidad es garantizar la resiliencia operativa ante incidentes críticos y el cumplimiento estricto de los derechos de los ciudadanos (especialmente el derecho de supresión del RGPD) sin comprometer la inmutabilidad inherente a la cadena de bloques.

Resultados esperados

- **Capacidad de interrupción:** Mecanismos efectivos para detener la operativa de un contrato ante amenazas de seguridad, mandatos legales o incumplimientos ("Kill Switch").
- **Cumplimiento por diseño:** Procedimiento técnico de borrado lógico (inutilización criptográfica) que garantiza el derecho al olvido mediante la destrucción de claves *off-chain*.
- **Seguridad jurídica:** Definición clara de responsabilidades entre ISBE (Encargado del Tratamiento) y el Participante (Responsable del tratamiento).
- **Trazabilidad:** Registro auditable de todas las acciones de intervención y borrado conforme al Esquema Nacional de Seguridad (ENS).

Ámbito de aplicación

Esta política aplica a:

- **Participantes:** Todos los Participantes responsables de *Smart Contracts* desplegados.
- **Activos:** La totalidad de *Smart Contracts* y datos gestionados en el ecosistema ISBE.
- **Órganos de Gobierno:** En sus funciones de supervisión, ejecución de medidas de emergencia y auditoría.

Relación con otros documentos

- ***ECO1020 - Política de gestión de casos de uso y SCs*:** Define los requisitos técnicos de arquitectura (Patrón Diamante) que hacen posible el pausado.
- ***INF1070 - Política de seguridad de la información:*** Establece los criterios para declarar un "Incidente de seguridad crítico".

Financiado por la Unión Europea NextGenerationEU
Plan de Recuperación, Transformación y Resiliencia
Comunidad de Madrid

- ***INF1080 - Política de gestión de incidencias*:** Regula el procedimiento operativo de respuesta ante alertas.
- ***GOB1020 – Política de organización y supervisión de la infraestructura ISBE:*** Define las competencias de los Comités responsables.
- En caso de conflicto entre la operativa de un contrato y la seguridad de la red, la **ECO1030 prevalece** para ejecutar medidas de contención.

Marco de referencia

La aplicación de esta política se alinea con:

- **Reglamento General de Protección de Datos (RGPD):** Garantía del derecho de supresión y seguridad del tratamiento.
- ***Data Act* (Reglamento de Datos):** Requisitos de interrupción y terminación de S*mart Contracts*.
- **Esquema Nacional de Seguridad (ENS):** Controles de trazabilidad, integridad y registro.
- **Directiva NIS2 y DORA:** Gestión de riesgos en la cadena de suministro y resiliencia operativa.

Fuera de alcance

- La gestión de copias de seguridad locales o bases de datos del Participante que estén fuera del perímetro de control de ISBE (responsabilidad exclusiva del Participante).

2. Definiciones y marco de referencia

2.1 Definiciones clave

- **Pausado (suspensión):** Interrupción temporal de la funcionalidad de un *Smart Contrac*t. Se ejecuta mediante una transacción técnica que activa un estado de "pausa", impidiendo nuevas operaciones críticas, pero manteniendo la integridad del contrato y los datos.
- **Bloqueo (retirada forzosa):** Interrupción definitiva e irreversible de un servicio por decisión de los Órganos de Gobierno. Implica el cese de actividad, la revocación de credenciales y la desvinculación del Catálogo.
- **Sal (*salt*):** Valor aleatorio secreto de alta entropía que, combinado con un dato personal *off-chain*, genera el hash registrado en la cadena.

- ***Hash* salado:** Evidencia criptográfica única registrada *on-chain*, resultante de aplicar una función hash al par (Dato + *Salt)*.

- **Inutilización criptográfica (*Crypto-shredding*):** Mecanismo técnico aceptado en ISBE para el borrado de datos. Consiste en la destrucción irreversible de la clave o el *salt* que permite vincular una evidencia *on-chain* con una persona física, haciendo que el *hash* remanente sea anónimo e inútil.

2.2 Otras definiciones

- **Responsable del tratamiento:** El Participante que despliega el caso de uso y determina los fines y medios del tratamiento de datos personales. Es el único responsable legal ante los usuarios finales y la AEPD.

- **Encargado del tratamiento:** La Entidad Gestora de ISBE, en su calidad de proveedor de la infraestructura tecnológica y los servicios de registro.

- ***Kill Switch*:** Capacidad técnica reservada a la gobernanza para detener la ejecución de un contrato de forma centralizada ante riesgos sistémicos.

- **Supuestos de activación:** Escenarios que legitiman la intervención: (1) Mandato de autoridad, (2) Incidente de seguridad, (3) Incumplimiento grave, (4) Mantenimiento voluntario.

2.3 Marco de referencia

Esta política se desarrolla en estricta conformidad con el marco regulatorio europeo y nacional:

- **Reglamento General de Protección de Datos (RGPD):** Base para la prohibición de datos en claro *on-chain* y la obligación de facilitar el derecho de supresión.

- ***Data Act* (Reglamento de Datos):** Requisitos de interrupción ("switch off") para *Smart Contracts* que operen con datos.

- **Esquema Nacional de Seguridad (ENS):** La política aplica las salvaguardas de nivel medio-alto relativas a la trazabilidad, integridad y registro de actividad.

- **Reglamento eIDAS 2:** Marco para los servicios de confianza y registro electrónico cualificado.

- **Estándares de Auditoría:** Posibilidad de auditoría conforme a ETSI EN 319 401 y ETSI TS 119 511 para garantizar la consistencia del registro.

2.4 Reglas de interpretación

- **Principio de proporcionalidad:** Las medidas de pausado o bloqueo impuestas por ISBE serán siempre proporcionales al riesgo detectado y se ejecutarán de forma no discrecional.

- **Responsabilidad indelegable:** La provisión de herramientas de borrado por parte de ISBE no exime al Participante de su responsabilidad legal de atender las solicitudes de sus usuarios en tiempo y forma.

3. Principios

Esta política se adhiere a los principios **C-FIRST** definidos en la Memoria de Gobernanza y establece los siguientes rectores específicos:

1. **Cumplimiento por diseño (C*ompliance by Design*):** La arquitectura técnica integra desde su origen los mecanismos necesarios (roles de pausa, separación de datos) para cumplir con el *Data Act* y el RGPD.

2. **Disociación entre prueba y dato:** Los datos personales residen siempre *off-chain*. La cadena de bloques se utiliza exclusivamente para registrar pruebas criptográficas inmutables (*hashes* salados), garantizando la integridad sin almacenar el contenido personal.

3. **Pausabilidad obligatoria:** Como requisito indispensable de homologación, todo *Smart Contract* debe implementar mecanismos técnicos que permitan su suspensión controlada ante emergencias.

4. **Responsabilidad del Participante:** El Participante actúa como responsable del tratamiento a todos los efectos legales. ISBE actúa como encargado del tratamiento (Proveedor de Infraestructura). El Participante es el responsable operativo de ejecutar el borrado de datos.

5. **Acción proporcional y auditada:** Cualquier intervención forzosa de ISBE (pausado/bloqueo) generará una traza auditable y se basará en procedimientos reglados, evitando la arbitrariedad.

6. **Conformidad con el ENS:** Los registros generados durante las acciones de pausado, bloqueo o borrado formarán parte del sistema de auditoría de ISBE y se conservarán conforme a los plazos establecidos en el Esquema Nacional de Seguridad.

Financiado por la Unión Europea NextGenerationEU
Plan de Recuperación, Transformación y Resiliencia

4. Roles y responsabilidades

La ejecución de las medidas de interrupción y borrado se distribuye entre los Órganos de Gobierno para garantizar la segregación de funciones, la proporcionalidad y la trazabilidad exigida por el marco de cumplimiento.

4.1 Roles del ecosistema

- **Órgano de Gestión:** Es el máximo responsable ejecutivo. Aprueba la presente política y sus modificaciones. Tiene la competencia exclusiva para tomar la decisión final motivada en los procedimientos de Suspensión o bloqueo por incumplimiento (Vía 2).
- **Órgano de Supervisión:** Garante de la neutralidad. Ratifica las resoluciones de expulsión o bloqueo definitivo adoptadas por el Órgano de Gestión para asegurar que no son arbitrarias.
- **Comité de Cumplimiento y Regulación:** Ejerce la supervisión global de la política (rol de CCRI). Evalúa la procedencia de los mandatos judiciales (Supuesto 1) y define el marco operativo de borrado de datos conforme al RGPD.
- **Comité de Procesos y Gestión de Riesgos:** Participa en la evaluación de los expedientes de bloqueo (Vía 2), analizando el impacto del riesgo para la red y garantizando que el procedimiento de audiencia se ejecuta correctamente.
- **Comité de Operaciones y Tecnología:** Responsable de la infraestructura y la intervención técnica. Define los estándares del "Kill Switch" y supervisa el marco operativo. Ejecuta el Pausado de Emergencia (Vía 1) ante incidentes críticos y aplica materialmente los bloqueos ordenados por el Órgano de Gestión.
- **Delegado de Protección de Datos (DPD):** Junto con el Comité de Cumplimiento y Regulación, audita y supervisa la correcta implementación del mecanismo de borrado de datos por parte de los Participantes.
- **Participante (Responsable del Tratamiento):** Ejecuta el Pausado Voluntario (Vía 3) y es el responsable operativo de realizar el borrado de datos y destrucción del *salt* ante sus usuarios.

4.2 Matriz RACI

La siguiente matriz define las responsabilidades en los procesos de intervención y gestión de derechos:

Proceso / Decisión	Participante	Comité de Operaciones y Tecnología	Comité de Cumplimiento y Regulación	Comité de Procesos y Gestión de Riesgos	Órgano Gestión	Órgano Supervisión
Pausado de emergencia (Vía 1)	I	R/A	C	I	I	—
Instrucción de bloqueo (Vía 2)	C	I	R	C	I	—
Audiencia y alegaciones	R	I	C	A	—	—
Resolución de bloqueo	I	C	C	C	A	C
Ejecución técnica de bloqueo	I	R	—	—	A	—
Pausado voluntario (Vía 3)	R/A	I	—	—	—	—
Ejecución de borrado (RGPD)	R/A	—	C	—	—	—

Leyenda:

Sigla	Significado	Descripción breve
R	*Responsible*	Ejecuta la acción.
A	*Accountable*	Aprueba/decide la acción y asume la responsabilidad final.
C	*Consulted*	Consulta preceptiva antes de decidir/ejecutar.
I	*Informed*	Informado del resultado/decisión.

5. Reglas obligatorias

La gestión de S*mart Contracts* y datos en ISBE está sujeta a reglas imperativas derivadas de los requisitos técnicos y legales definidos en el marco operativo.

5.1 Reglas de arquitectura para la interrupción

Regla 1. Pausabilidad obligatoria.

Todo *Smart Contract* desplegado en ISBE debe implementar mecanismos técnicos que permitan la suspensión controlada de sus funciones críticas. El cumplimiento de esta regla es un requisito indispensable para la homologación (*ECO1020 - Política de gestión de casos de uso y SCs*).

Regla 2. Patrón Diamante y modularidad.

Es obligatorio el uso del Patrón Diamante (EIP-2535). La lógica de negocio debe residir en módulos (*facets*) que puedan ser deshabilitados o reemplazados sin afectar al almacenamiento.

Regla 3. Roles de emergencia.

Los contratos deben implementar roles específicos de pausa (*PAUSER_ROLE*) y proteger las funciones de modificación de estado con modificadores.

5.2 Reglas de privacidad y gestión del dato

Regla 4. Prohibición de datos *on-chain.*

Queda terminantemente prohibido almacenar datos personales (PII) o sensibles directamente en un *Smart Contract* o en los logs de eventos. El incumplimiento de esta norma se considera un incumplimiento grave (Supuesto 3).

Regla 5. Almacenamiento *off-chain.*

Los datos personales deben almacenarse exclusivamente en sistemas externos (bases de datos *off-chain*) bajo el control del Participante.

Regla 6. *Hash* salado.

Toda evidencia registrada *on-chain* debe ser criptográfica, consistente en el *hash* del dato original combinado obligatoriamente con un "salt" (valor aleatorio secreto) para impedir ataques de fuerza bruta.

5.3 Reglas de borrado (inutilización criptográfica)

Regla 7. Procedimiento de ejecución.

Financiado por la Unión Europea NextGenerationEU
Plan de Recuperación, Transformación y Resiliencia
Comunidad de Madrid

Para cumplir el derecho de supresión, el Participante debe ejecutar el siguiente protocolo estricto:

1. Eliminar el dato personal de su sistema *off-chain*.
2. Destruir irreversiblemente el "salt" asociado a ese dato.
3. Asegurar la ruptura del vínculo, haciendo que el *hash on-chain* sea matemáticamente inútil.

Regla 8. Auditoría del borrado.

El Participante es responsable de generar evidencias de la destrucción del *salt.* ISBE podrá auditar este proceso para verificar el cumplimiento.

5.4 Reglas de intervención (vías de pausado)

Regla 9. Vía 1 - Emergencia.

ISBE ejecutará el pausado inmediato y sin audiencia previa en caso de Mandato de autoridad (Supuesto 1) o Incidente de seguridad crítico (Supuesto 2). La prioridad es mitigar el daño a la red. Se notificará *a posteriori.*

Regla 10. Vía 2 - Disciplinaria.

Ante un Incumplimiento grave de políticas (Supuesto 3), se seguirá un procedimiento formal que garantiza el derecho de audiencia del Participante. El bloqueo definitivo requiere resolución del Órgano de Gestión.

Regla 11. Vía 3 - Voluntaria.

El Participante puede pausar sus contratos por mantenimiento (Supuesto 4). Debe notificarlo previamente al Comité de Operaciones y Tecnología para evitar falsas alarmas de seguridad.

5.5 Mecanismo de filtrado técnico y régimen sancionador

Esta sección incorpora las capacidades del componente de "Compliance by Design" de la infraestructura ISBE.

Regla 12. Filtrado RPC (Capa *Middleware*).

Además de los mecanismos internos del contrato (pausa), ISBE implementa una capa de filtrado en los nodos (Middleware/Proxy) capaz de interceptar y bloquear peticiones JSON-RPC para garantizar el cumplimiento normativo.

Regla 13. Alcance del bloqueo técnico.

Financiado por la Unión Europea NextGenerationEU
Plan de Recuperación, Transformación y Resiliencia
Comunidad de Madrid

ISBE se reserva el derecho de activar filtros técnicos granulares sobre cualquier activo de la red ante incidentes. Estos filtros pueden bloquear:

- **Llamadas (*eth_call*):** Restricción de acceso a contratos específicos o métodos concretos (*method signature*) dentro de un contrato.
- **Transacciones (*eth_sendRawTransaction*):** Bloqueo de la emisión de nuevas transacciones, despliegues o interacción con funciones vulnerables.
- **Datos históricos (*eth_getLogs*, *eth_getBlock*):** Bloqueo de lectura de rangos de bloques específicos que contengan información ilícita o datos personales expuestos, impidiendo su visualización a través de la API.

Regla 14. Integridad y penalización.

Los mecanismos de filtrado son parte integral de la seguridad de la red. Cualquier intento intencionado por parte de un Participante de eludir, ofuscar o burlar estos filtros técnicos se considerará una infracción muy grave. Dicha conducta podrá conllevar la inhabilitación del Participante y la aplicación de las penalizaciones estipuladas.

6. Procedimientos clave

Los siguientes procedimientos describen la operativa para la gestión de crisis y derechos de los usuarios. Se ejecutan bajo un estricto control de auditoría y trazabilidad.

6.1 Vía 1: Pausado de emergencia (actuación de oficio)

Objetivo. Detener de forma inmediata una amenaza inminente para la red o cumplir un mandato judicial perentorio, sin trámite de audiencia previo debido a la urgencia.

Ámbito / roles

- **Comité de Operaciones y Tecnología:** Ejecutor.
- **Comité de Cumplimiento y Regulación:** Solicitante.

Entradas

- **Supuesto 1:** Mandato de autoridad competente (Orden judicial/AEPD).
- **Supuesto 2:** Incidente de seguridad crítico (ej. *Exploit* en curso, robo masivo).

Pasos

1. **Detección/recepción:** El Comité competente recibe la alerta o el mandato judicial.
2. **Calificación del riesgo:** Se verifica que la amenaza es crítica y requiere acción inmediata.
3. **Ejecución inmediata:** El Comité de Operaciones y Tecnología ejecuta el pausado técnico (*Kill Switch*) sin audiencia previa para congelar el estado del contrato.
4. **Notificación:** Inmediatamente después (T+0), se notifica formalmente al Participante y al Órgano de Gestión, documentando la causa.

Salidas

- Contrato en estado “PAUSADO” (solo lectura).
- Informe de incidente.

Plazos / SLA

- **Ejecución:** Inmediata tras calificación (< 4 horas).

Evidencias

- *Hash* de la transacción de pausa.

- Copia del mandato judicial o *log* del incidente de seguridad.

6.2 Vía 2: Bloqueo disciplinario (retirada forzosa)

Objetivo. Sancionar un incumplimiento grave de políticas mediante la retirada definitiva del servicio, garantizando el debido proceso.

Ámbito / roles

- **Comité de Cumplimiento y Regulación:** Instructor.
- Comité de Procesos y Gestión de Riesgos.
- **Órgano de Gestión:** Decisor.

Entradas

- **Supuesto 3:** Incumplimiento grave (ej. PII *on-chain*, fraude, negligencia reiterada).

Pasos

1. **Instrucción:** El Comité de Cumplimiento y Regulación documenta el incumplimiento detectado.
2. **Audiencia:** El Comité de Procesos y Gestión de Riesgos notifica al Participante, otorgándole un plazo para presentar alegaciones o subsanar.
3. **Resolución:** Elevación de la propuesta al Órgano de Gestión, que dicta la resolución final motivada.
4. **Ejecución:** El Comité de Operaciones y Tecnología revoca las credenciales del Participante y, si es técnicamente posible, ejecuta el bloqueo permanente del contrato.

Salidas

- Contrato "BLOQUEADO/RETIRADO".
- Baja del Catálogo (CSC).

Plazos / SLA

- **Resolución del expediente:** ≤ 15 días hábiles (salvo medidas cautelares).

Evidencias

- Expediente sancionador y alegaciones.
- Resolución firmada del Órgano de Gestión.

6.3 Vía 3: Pausado voluntario (mantenimiento)

Objetivo. Permitir al Participante gestionar el ciclo de vida técnico de su aplicación de forma autónoma.

Ámbito / roles

- **Participante:** Ejecutor.
- **Comité de Operaciones y Tecnología:** Informado.

Entradas

- **Supuesto 4:** Mantenimiento programado o decisión de negocio.

Pasos

1. **Notificación:** El Participante comunica al Comité de Operaciones y Tecnología la ventana de mantenimiento prevista.
2. **Ejecución:** El Participante utiliza sus propios roles de gobernanza (*PAUSER_ROLE*) para pausar el contrato.
3. **Comunicación:** El Participante informa a sus usuarios finales sobre la interrupción del servicio.

Salidas

- Contrato en estado “PAUSADO” temporalmente.

Plazos / SLA

- **Validación de negocio:** ≤ 10 días hábiles.

Evidencias

- Comunicación de mantenimiento al Comité.

6.4 Procedimiento de borrado de datos

Objetivo. Ejecutar técnicamente el derecho de supresión rompiendo el vínculo criptográfico de forma irreversible.

Ámbito / roles

- **Participante:** Responsable.
- **Delegado de Protección de Datos (DPD) de ISBE:** Auditor.

Entradas

- Solicitud de ejercicio de derechos (Supresión) por un usuario final.

Pasos

1. **Validación:** El Participante valida la identidad del solicitante.

2. **Borrado off-*chain*:** El Participante elimina los datos personales de sus bases de datos.
3. **Destrucción del *salt*:** El Participante localiza y destruye de forma irreversible el valor aleatorio (*salt*) asociado a ese usuario.
4. **Verificación:** Se confirma que, sin el *salt*, el hash registrado en la *blockchain* es matemáticamente imposible de re-identificar.
5. **Registro:** El Participante genera un *log* de la operación para auditoría.

Salidas

- Dato personal eliminado.
- *Hash on-chain* convertido en dato anónimo irrecuperable.

Plazos / SLA

- **Atención solicitud:** Plazo legal RGPD (1 mes).

Evidencias

- *Log* de borrado del sistema del Participante (trazabilidad auditada).

7. Supervisión, revisión y actualización

Este punto define cómo se controla el cumplimiento de ECO1030, cada cuánto se revisa y cómo se actualiza la política cuando cambian las condiciones.

7.1 Objetivo y alcance de la supervisión

Verificar que los mecanismos de "Kill Switch" funcionan correctamente y que los Participantes cumplen con sus obligaciones de privacidad, protegiendo a ISBE de riesgos legales y reputacionales conforme al modelo PDCA (*Plan-Do-Check-Act*).

7.2 Indicadores y umbrales (KPI mínimos)

- **Tiempo de respuesta ante incidentes críticos (Vía 1):** ≤ 4 horas desde la detección.
- **Solicitudes de borrado (RGPD) atendidas en plazo:** 100% (Responsabilidad del Participante).
- **Tasa de falsos positivos en alertas de seguridad:** ≤ 5%.
- **Auditorías de borrado satisfactorias:** % de Participantes auditados que demuestran correcta gestión del *salt* (≥ 95%).

7.3 Revisión y actualización de la política

- **Revisión ordinaria:** Anual (cada 12 meses), liderada por el Comité de Cumplimiento y Regulación y el Comité de Operaciones y Tecnología.
- ***Triggers* de revisión extraordinaria:** Cambios en el Reglamento de Datos (*Data Act)* o RGPD, nuevas directrices de la AEPD/EDPB sobre *blockchain* o fallos detectados en los mecanismos de criptografía.

Financiado por la Unión Europea NextGenerationEU
Plan de Recuperación, Transformación y Resiliencia
Comunidad de Madrid

8. Anexos

No aplica.